

AICA LEVEL 2 · CAPSTONE PROJECT

SurakshaScan

A DPDP readiness scanner for educational institutions

Project Summary Document

Digital Personal Data Protection Act, 2023 · DPDP Rules, 2025

CA Aditi Gulati

Deputy Director, Little Flower House Senior Secondary School & College, Varanasi

AI for Chartered Accountants — Level 2 · Batch 89, Gurugram

September 2026

Contents

1. Executive summary
 2. The problem
 3. What SurakshaScan does
 4. Design principles
 5. Legal foundation
 6. How the AICA Level 2 syllabus is applied
 7. Technology and architecture
 8. Testing and verification
 9. Outputs
 10. Limitations
 11. Future scope
 12. How to run it
 13. Contents of this submission
-

1. Executive summary

Under the Digital Personal Data Protection Act, 2023, everyone below eighteen is a child. For a school, that is the entire student body. The school is the **Data Fiduciary** — responsible for every item of that data, including what its ERP vendor, fee gateway and learning platform do with it.

Most schools do not know what personal data they hold, where it sits, or which of the Act's obligations already bind them. SurakshaScan is a desktop tool that answers those questions with evidence.

It reviews a school against **33 obligations** drawn from the Act and the DPDP Rules, 2025, across **five surfaces**: the public website, the published privacy policy, the school's own social media posts, its core systems (ERP, accounts, learning platform), and a 39-line internal-practices working paper. It produces a scored Word report, an Excel workbook, a mobile-friendly HTML dashboard and a timestamped evidence file.

The central design decision: every rating comes from a deterministic rules engine, so the same inputs always produce the same score. An optional AI layer adds quoted evidence and drafting help, but it can never change a rating — and any AI finding whose quotation does not appear in the policy is rejected in print.

Measure	Result
Obligations assessed	33, across 8 domains, each with its provision and commencement date
Surfaces reviewed	Website · policy · social media · core systems · internal practices
Working paper	39 lines across 7 tabs, audit working-paper conventions
Code	About 8,250 lines of Python across 36 modules
Tests	87 automated tests, all passing, run offline against fixtures
Outputs	Word report · Excel workbook · HTML dashboard · evidence JSON

2. The problem

A school is unusual among Data Fiduciaries in three ways, and each one makes the DPDP Act harder for it than for a typical business.

- **Its Data Principals are children.** Section 9 requires verifiable parental consent before processing a child's data, and prohibits tracking, behavioural monitoring and targeted advertising directed at children.
- **Its data is spread thin.** Student records sit in the ERP; fee receipts in the accounts; coursework on a learning platform; photographs on Instagram; CCTV on a recorder in the office. No one person sees all of it.
- **It believes it is exempt.** Rule 12 read with Part A of the Fourth Schedule does exempt an educational institution from sections 9(1) and 9(3). Most schools read that far and stop.

The point most schools miss

The Fourth Schedule exemption is **purpose-bound**. It covers academic activities, tracking and behavioural monitoring, and the safety of enrolled students — and nothing else. It does not reach a promotional photograph, an alumni database, a prospective student who has not enrolled, or an

advertising pixel on a public web page. Getting that boundary right is most of the value SurakshaScan adds.

3. What SurakshaScan does

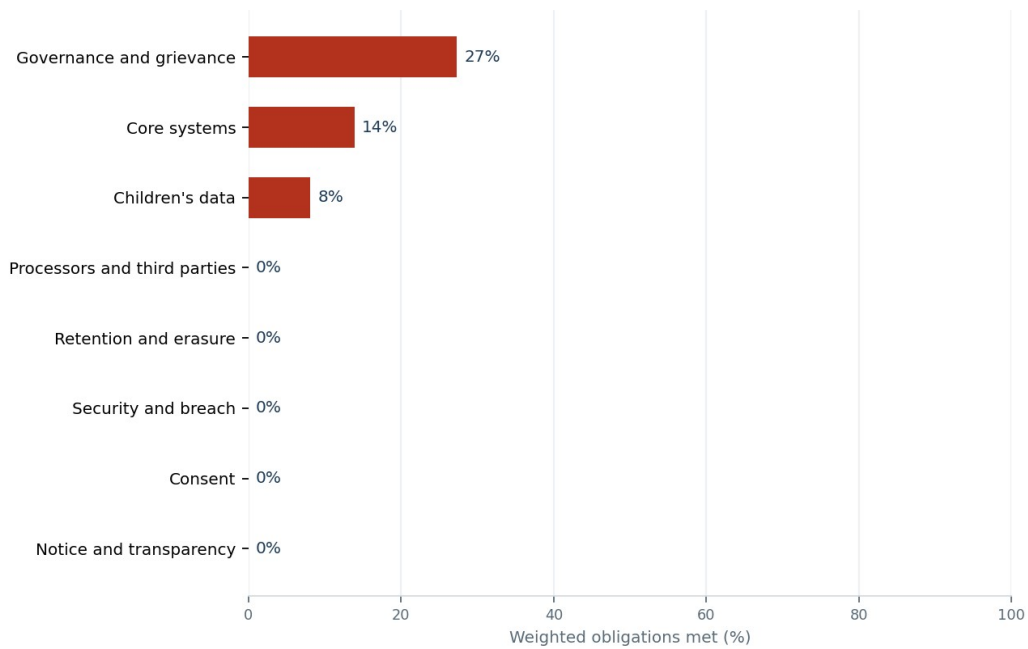
Surface	What is examined	How
Website	Forms and the data they ask for, trackers, HTTPS, contact details, consent wording	A polite crawler that obeys robots.txt, rate-limits itself and never logs in
Privacy policy	Whether the notice meets section 5 and Rule 3	Found and read, not just linked to; matched against the obligation catalogue
Social media	Posts naming a child with a class, roll numbers, boosted posts featuring children	Only the school's own posts; captions analysed, never faces; never scraped
Core systems	What the ERP, accounts and learning platform actually hold	Reads the shape of an export — column names and counts — never the data
Internal practices	Vendor contracts, retention, breach procedure, media consent	A 39-line working paper with mandatory reviewer and neutral remarks

For every contested finding, a two-perspective panel sets out the school's position and the parent's or the Board's position on identical facts — and what actually decides it.

A sample result

Run against the built-in demonstration school, SurakshaScan returns a score of **9/100 (Critical)**, with 58% of the catalogue assessable. It always reports coverage beside the score: a high score over a thin scan is not a well-run school.





4. Design principles

Five decisions shape the whole tool. Each is enforced in code, and each has tests that fail if it is broken.

1. **The rules engine is authoritative; the AI is advisory.** Same website, same working paper, same score. The AI layer adds quoted evidence and drafting help and cannot change a rating.
2. **The AI cannot claim what it cannot quote.** A positive AI finding must quote a passage that appears word-for-word in the policy, or it is rejected — and the rejection is printed in the report.
3. **It reads the shape of the data, never the data.** ERP and accounts exports yield column names, categories and counts only. A compliance tool that accumulated every school's student database would be a worse problem than the one it finds.
4. **It never scrapes social media.** It reads only the school's own posts, through an export the school supplies or screenshots. Captions are analysed; no face recognition is ever performed on a child.
5. **It records who authorised the review.** The tool refuses to run until the name and designation of the authorising person is entered, and prints it on every report.

Why the authorisation matters

Section 3(c)(ii) exempts publicly available data only where it was made public by the Data Principal, or by someone under a legal obligation to publish it. A school posting a child's photograph is neither. So that photograph stays fully within the Act, and reading another school's feed without consent would make the reviewer a **Data Fiduciary with no lawful basis**. Every external review in this project was carried out with the written authorisation of the school's principal.

5. Legal foundation

Each obligation carries the section or rule it comes from, the date that provision commences, and a weight reflecting its importance to a school.

Domain	Obligations	Weight	Examples
Notice and transparency	6	28	Notice published; categories itemised; withdrawal route; Board complaint route
Consent	3	13	Affirmative action; data minimisation; auditable records
Children's data	8	48	Verifiable parental consent; s.9(3) tracking ban; social media; media consent
Security and breach	3	17	HTTPS; reasonable safeguards; breach procedure
Retention and erasure	2	10	Retention schedule; CCTV and biometric rules
Governance and grievance	4	20	Published contact; grievance route; record of processing
Core systems	4	23	ERP minimisation; erasing leavers; accounts retention conflict; LMS
Processors and third parties	3	14	Vendor contracts; trackers disclosed; cross-border position

Commencement

The DPDP Rules, 2025 were notified on 13 November 2025 and commence in three phases. The Act's own duties — sections 5, 6 and 8 — bind now. SurakshaScan labels every finding accordingly, so what is due today is never confused with what is due later.

Phase	Date	Rules
1	13 November 2025	Rules 1, 2 and 17–21 (definitions, the Board, appeals)
2	14 November 2026	Rule 4 (Consent Managers)
3	14 May 2027	Rules 3, 5–16 and 22 (notice, security, breach, retention, children, rights)

6. How the AICA Level 2 syllabus is applied

The capstone is one working tool, not five exercises. Each day's learning is carried into a specific part of it.

Day	Learning	Where it appears in SurakshaScan
1	Structured prompting; reusable skills; scheduling; separate approvals	Role + Context + Objective + Format + Examples prompt with few-shot; a packaged DPDP review skill; a quarterly re-scan that queues results for a person rather than sending them
2	Computer vision; comparing two perspectives	Review of admission forms, consent slips and post screenshots with uncertainty flags; the two-perspective panel for every contested finding

Day	Learning	Where it appears in SurakshaScan
3	Python; desktop applications; PyInstaller	BeautifulSoup, python-docx, openpyxl, matplotlib, PyMuPDF and Tkinter; a standalone Windows executable
4	Business applications; audit working paper; dashboards	Tabbed working paper with Completed / In Progress / Pending / NA, mandatory reviewer, neutral remark; donut and bar charts; Word, Excel and HTML exports
5	MCP; TallyPrime; workflow automation	An MCP server, read-only by default; a read-only TallyPrime ledger check over the local port; an n8n trigger → action → review → output workflow

The running themes — data safety, verification, separate approvals, reusability, compliance, narrow permissions and audit trail — are mapped module by module in *05_Supporting_Documents/02_Five_Day_Syllabus_Map.md*.

7. Technology and architecture

Four front ends — the desktop app, the command line, an MCP server and an n8n workflow — all call one orchestration engine, so a result cannot depend on which door it came through.

Layer	Components
Interface	Tkinter desktop app (8 tabs) · command line · MCP server · n8n workflow
Evidence gathering	Website crawler · policy reader · social media reader · ERP/LMS export analyser · TallyPrime reader · document vision
Assessment	Obligation catalogue · deterministic rules engine · working-paper overlay · optional AI layer with anti-hallucination guards
Analysis	Weighted scoring with coverage · prioritised remediation · two-perspective panels
Output	Word report · Excel workbook · HTML dashboard · evidence JSON with secrets redacted
Libraries	requests, BeautifulSoup, python-docx, openpyxl, matplotlib, PyMuPDF, Pillow, Tkinter, PyInstaller

8. Testing and verification

SurakshaScan has **87 automated tests**, all passing, run entirely offline against fixture websites and exports. They cover the scanner, the rules engine, scoring, the AI guards, every report, the social and core-systems modules, the authorisation requirement, and a headless build of the desktop window.

Several tests exist to prove the tool will not do something:

- the AI layer cannot assert an obligation is met without quoting real text;
- no child's name, Aadhaar number or address can reach the evidence file;
- no scraping code can appear in the social media module;
- the TallyPrime request can never contain Import, Alter, Delete or Create;
- no web page is fetched before the authorisation is checked.

What testing found

Using the tool on real data surfaced defects the unit tests did not. A Meta pixel matching three signatures was being counted three times. Three argument panels were word-for-word identical. Twice, a whole module's results were computed and then silently dropped before reaching the report — both caught by the offline self-test printing an empty tick box. The Ctrl+V paste key was bound to a widget that never receives keyboard focus. Each was fixed and given a regression test.

9. Outputs

Output	For	Contents
Word report	The management committee	Overview with score and charts; prioritised actions; findings by obligation; two-perspective panels; working paper; social media; core systems; evidence appendix
Excel workbook	Whoever does the work	Findings, remediation plan with blank Owner / Target date / Done columns, working paper, trackers, evidence log
HTML dashboard	A principal on a phone	Single self-contained file, charts embedded, no internet needed, collapses to one column on mobile
Evidence file	An auditor, months later	Timestamped JSON of everything the scan saw and concluded, secrets redacted

10. Limitations

- **Public surfaces only.** The website scan never logs in. Internal practice is covered by the working paper, which depends on honest answers.
- **Hindi captions.** Devanagari has no capital letters, so names cannot be extracted from Hindi posts the way they are from English ones. Such posts are flagged for a person to read rather than guessed at.
- **Unsigned executable.** Windows Smart App Control blocks unsigned apps outright. A code-signing certificate would resolve this; until then the tool also runs from source.
- **A young law.** Commencement dates and the Fourth Schedule wording should be re-verified against the notified text before any report is relied upon.

11. Future scope

- Name recognition for Devanagari captions, reviewed against a labelled sample before use.
- A signed, installable Windows build.
- A multi-school benchmark that stores only aggregate scores, never identifiers.
- Connectors for the ERP products most common in Indian schools, reading structure only.

12. How to run it

Without Python: double-click *SurakshaScan.exe* in *04_Executable_Files*.

From source:

```

pip install -r requirements.txt
python -m surakshascan.tools.demo      # offline self-test
python run.py                          # the desktop app

```

The self-test scans the bundled demonstration school, writes all three reports and checks eight findings. If it prints "Self-test passed", the installation works.

13. Contents of this submission

Folder	Contents
01_Project_Summary_Document	This document
02_Prompt_Files	The policy-analysis prompt, the vision prompt, the reusable DPDP review skill, and the development prompts used to build the tool
03_Example_Files	Sample inputs (ERP, learning platform, social media, Tally, website) and outputs (Word, Excel, dashboard, evidence file)
04_Executable_Files	SurakshaScan.exe and the complete source code with build instructions
05_Supporting_Documents	Architecture, syllabus map, obligation catalogue, module guides, the n8n workflow, and the version 1 baseline

Disclaimer. SurakshaScan performs a readiness review. It is not a certificate of compliance with the Digital Personal Data Protection Act, 2023 or the Digital Personal Data Protection Rules, 2025, and it is not legal advice. All sample outputs in this submission are from a fictitious demonstration school.